

Compliance Approval Process for AI Use Cases

Nova Insurance Group | Process Document NIG-PROC-COMP-004

1. Overview and Objectives

This document describes the mandatory compliance approval process that all new AI use cases at Nova Insurance Group must complete before deployment. The process ensures that AI systems are assessed for legal, ethical, technical and regulatory compliance — including alignment with the EU AI Act, GDPR, Solvency II, and internal policies — before they begin processing real data or influencing business decisions.

The Compliance team is the gate-keeper for this process. The AI Review Board (ARB), convening monthly, makes final approval decisions on high-risk use cases. Expedited reviews are available for time-critical business needs.

2. When Approval is Required

Compliance approval is required whenever any of the following conditions are met:

- A new AI tool, model or service is proposed for use in any Nova business function.
- An existing approved AI tool is extended to a new data type (e.g., adding health data to a previously approved analytics tool).
- An AI tool is to be used to influence decisions that affect customers, their coverage, premiums or claims.
- AI-generated outputs will be included in regulatory filings, financial reports or external communications.
- A third-party AI vendor or API is being contracted for the first time.
- An existing use case is materially changed (new model version with different capabilities, new training data, new output format).
- Automated decision-making will be applied to individuals without meaningful human review (Art. 22 GDPR).

3. The Four-Stage Approval Process

Stage 1 — Request Submission (Day 1)

- The requesting team completes the AI Use Case Registration Form (Form NIG-F-AI-01) available on the intranet.
- The form captures: use case description, data types involved, tool/vendor name, intended output and decision impact.
- The completed form is submitted via the Compliance Portal (<https://intranet.nova-insurance.eu/compliance/ai-register>).
- The submitter's Line Manager must co-sign the form, confirming business justification.

Stage 2 — Initial Screening (Days 1–3)

- The Compliance team conducts a triage review within 3 business days.
- Use cases are categorised as: (a) Standard Review, (b) Enhanced Review (involving customer data or automated decisions), or (c) High-Risk Review (requiring ARB approval).
- The requesting team is notified of the category and estimated timeline.
- Incomplete submissions are returned within 2 business days with a request for additional information.

Stage 3 — Full Assessment (Days 3–10)

- Compliance reviews the use case against the AI Usage Policy (NIG-POL-AI-001), Data Privacy Guideline (NIG-GDL-DPR-002), EU AI Act risk classification, and sector regulations.
- For Enhanced/High-Risk reviews: IT Security conducts a technical and vendor due-diligence assessment; DPO conducts a DPIA where required.
- Legal reviews any vendor contracts or API terms of service.
- The assessment outcome is documented in the AI Use Case Assessment Report.

Stage 4 — Decision and Registration (Days 10–12)

- Standard reviews: approved or rejected by the Chief Compliance Officer.
- High-Risk reviews: presented to the AI Review Board at the next monthly session (expedited ARB meeting can be convened within 5 business days on request).
- Approved use cases are registered in the AI Inventory with an approval reference number.
- Rejected use cases receive a written decision with the reason(s) for refusal; a revised submission may be resubmitted after addressing the stated concerns.

4. Documentation Requirements

Each approved AI use case must maintain the following documentation, accessible to Compliance and the DPO at any time:

Document	Owner	Update Frequency
AI Use Case Registration Form	Requesting Team	At submission; update on material change
AI Use Case Assessment Report	Compliance / DPO / IT Security	Per review cycle
Data Protection Impact Assessment (DPIA)	DPO	At approval; annually thereafter
Vendor / API Data Processing Agreement	Legal	At contract signing; on renewal
AI Output Log	Requesting Team / IT	Continuous (automated where possible)
Human Review Record	Requesting Team	Per decision (for automated outputs)

5. What Must Be Documented for AI-Generated Content

When AI-generated content is used in internal or external documents, the following must be recorded:

- The AI tool used (name, version, approval reference number).
- The prompt or input provided (or a description of the prompt type if the content is sensitive).
- Date and time of generation.
- Name and role of the employee who reviewed the output.

- Any material changes made by the reviewer to the AI-generated content.
- The final document or communication in which the AI-generated content appears.
- Whether the recipient (internal or external) was informed of AI involvement.

These records must be retained for a minimum of 3 years and made available to the Compliance team on request. For customer-facing content, records must be retained for the duration of the customer relationship plus 5 years.

6. Expedited Approval

Where a business-critical deadline requires faster approval, the requesting team may submit an Expedited Review Request alongside the standard registration form. The request must be co-signed by a member of the Executive Committee. Expedited reviews target a 5 business-day turnaround. Approval under the expedited process is conditional and may be subject to additional retrospective documentation requirements.

7. Ongoing Monitoring and Annual Review

Approval is not a one-time gate. All approved AI use cases are subject to:

- Annual reassessment by the Compliance team.
- Mandatory notification of material changes to the Compliance Portal within 5 business days of the change.
- Incident reporting: any unexpected AI output, model drift or data breach linked to the use case must be reported immediately.
- Spot audits conducted by the Internal Audit function.